COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.5 · Segmentation & Access Control

Mestre CyberSec · **Lesson 2.5 — Segmentation & Access Control** (6:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Isolamento network: VLAN / sub-rede / DMZ (screened subnet) — se um setor compromete, não contamina o resto. ACL (Access Control List) = o QUE pode entrar no recurso. Allowlist (default DENY — só o conhecido passa) > denylist (default ALLOW — bloqueio o conhecido). Microsegmentaç

💡 Key Exam Highlights & Critical Concepts

- DMZ: zona entre internet e rede interna — o público mora lá
- Allowlist (deny-by-default) é MAIS SEGURA que denylist
- Microsegmentação: cada carga isolada — Zero Trust aplicado

🎯 Exam Tips & Typical CompTIA Scenarios

- 'default deny, permit only known' = allowlist
- 'zone between internet and internal network' = DMZ/screened subnet

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.5 — Segmentation & Access Control)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Virtual Local Area Network (VLAN)

Logical segmentation of a physical network that groups devices into separate broadcast domains, regardless of physical location, to isolate traffic and reduce attack exposure.

⚠ ***Exam Trap:*** *Trigger: 'segment a network logically without new hardware' or 'separate broadcast domains' → VLAN. Do not confuse with subnetting (Layer 3); VLANs operate at Layer 2.*

• Demilitarized Zone (DMZ)

A screened subnet or perimeter network placed between an untrusted network (Internet) and a trusted internal network, hosting public-facing services like web and email servers to protect internal assets.

⚠ ***Exam Trap:*** *Trigger: 'zone between the Internet and the internal network' or 'place to put public-facing servers' → DMZ/screened subnet. CompTIA often uses 'screened subnet' as a synonym.*

• Access Control List (ACL)

A set of rules applied to network interfaces or resources that filters traffic or access based on IP, port, protocol, or user identity, defining what is allowed or denied.

⚠ ***Exam Trap:*** *Trigger: 'rules that define what traffic is permitted' or 'rule-based filtering on a router/firewall' → ACL. Know the difference: ACL = WHAT can enter; firewall often enforces broader rules including stateful inspection.*

• Allowlist (Default Deny) (N/A)

A security approach where only explicitly approved items (IPs, applications, users) are granted access, and everything else is implicitly denied by default.

⚠ ***Exam Trap:*** *Trigger: 'default deny, permit only known' or 'most secure access policy' → Allowlist. CompTIA considers allowlist MORE secure than denylist because it blocks unknown threats proactively.*

• Denylist (Default Allow) (N/A)

A security approach where everything is allowed by default and only specifically identified items are blocked, commonly used for known malicious IPs or applications.

⚠️ ***Exam Trap:*** *Trigger: 'block only known bad traffic' → Denylist. Less secure because zero-day/new threats pass through; CompTIA recommends allowlist for high-security environments.*

- **Microsegmentation (N/A)**

A security architecture that divides a network into very small, isolated zones (often per workload, application, or device) to apply granular security policies and limit lateral movement.

⚠️ ***Exam Trap:*** *Trigger: 'isolate each workload individually' or 'apply Zero Trust at the workload level' → Microsegmentation. Key distinction: traditional segmentation uses broad zones; microsegmentation uses tiny per-asset boundaries.*

- **Zero Trust (N/A)**

A security model that assumes no implicit trust for any user, device, or network location, requiring continuous verification and least-privilege access for every access request.

⚠️ ***Exam Trap:*** *Trigger: 'never trust, always verify' or 'no implicit trust based on network location' → Zero Trust. Pairs directly with microsegmentation and applies to internal AND external requests.*

- **Subnet (Subnetwork) (N/A)**

A logical subdivision of an IP network that separates hosts into smaller groups using subnet masks, enabling traffic isolation and efficient routing.

⚠️ ***Exam Trap:*** *Trigger: 'segment a network at Layer 3' or 'divide network using subnet masks' → Subnet. Differentiate from VLAN (Layer 2): subnetting uses IP addressing; VLANs use switch ports/tags.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 VLANs (Virtual Local Area Networks)

🏠 **Real-World Analogy:** Imagine a commercial office where Finance, HR, and the Guest Lobby share the same floor, but each sits behind locked soundproof walls. Even if a visitor yells in the lobby (generating a network broadcast storm), nobody in Finance hears a whisper. A VLAN constructs logical security walls inside the same physical switch, stopping unauthorized cross-department chatter.

🔍 **Root Cause & Background:** In legacy flat networks, any compromised machine can broadcast frames to every neighboring endpoint and sniff unencrypted packets. Absent network segregation, lateral infection vectors spread unrestricted across entire organizations.

🛡️ **GRC Auditor Perspective:** Verify network topology compliance against regulatory frameworks (such as PCI-DSS Cardholder Data Environment segregation); inspect switch configurations ensuring Management and Guest VLANs are partitioned away from core assets.

⚠️ **How CompTIA Tests This:** Trigger: 'logical segmentation implemented on a network switch to contain broadcast traffic and enforce boundaries between departments'. Answer: VLAN (Virtual Local Area Network).

📌 DMZ / Screened Subnet (Perimeter Isolation)

🏠 **Real-World Analogy:** It is like a secured reception room in an international embassy. External guests are admitted to conduct business, but locked security checkpoints prevent visitors from slipping into private offices or diplomatic archives. A DMZ hosts public-facing servers (web, mail) while shielding internal databases from direct internet exposure.

🔍 **Root Cause & Background:** Placing internet-facing web servers directly inside internal corporate subnets means a single application compromise yields total network access. A DMZ establishes a semi-trusted buffer zone segregated by firewalls on both sides.

🛡️ **GRC Auditor Perspective:** Audit perimeter and internal firewall policy rulebases; enforce the foundational DMZ architectural principle forbidding any connection initiated from the DMZ directly into internal network zones.

⚠️ **How CompTIA Tests This:** Trigger: 'perimeter network segment housing public-facing servers, isolated from the internal network by firewalls'. Answer: DMZ / Screened Subnet.

📌 Air Gap (Physical Isolation)

🏠 **Real-World Analogy:** It is like placing a mainframe inside an underground bunker with no network cables, no Wi-Fi chips, no Bluetooth transmitters, and no external wiring. Transferring data requires an authorized courier to carry a verified physical media device on foot into the room. There are no cables or radio signals for remote hackers to bridge.

🔍 **Root Cause & Background:** Any logical network link remains susceptible to firmware zero-days and protocol vulnerabilities. For mission-critical infrastructure (nuclear SCADA plants, avionics flight computers, offline PKI root CAs), physical disconnection is the ultimate assurance of remote impenetrability.

🛡️ **GRC Auditor Perspective:** Physically inspect offline Root CA vaults and industrial control (OT) cleanrooms; verify the complete absence of wireless adapters or unauthorized dual-homed network bridges; audit removable media scanning stations.

⚠️ **How CompTIA Tests This:** Trigger: 'system is completely disconnected and physically isolated from all external networks and communication links to ensure maximum security'. Answer: Air Gap (Classic CompTIA scenario: Offline Root CA).

📌 Microsegmentation (Cloud & Container Zero Trust)

🏠 **Real-World Analogy:** In a traditional hotel, once past the front desk, any guest can roam hallways and knock on any bedroom door. In microsegmentation, every room features an individualized vault lock permitting only the authorized room service attendant to deliver designated meals. If room 101 catches fire, flames cannot leap to room 102.

🔍 **Root Cause & Background:** Perimeter firewalls only inspect North-South boundary traffic. Once attackers establish a foothold, they pivot across East-West lateral lanes unimpeded. Microsegmentation enforces host-level virtual firewalls directly on individual virtual workloads.

🛡️ **GRC Auditor Perspective:** Audit cloud Security Groups and software-defined network policies; ensure database workloads strictly permit ingress traffic from authorized application security groups while dropping all other peer traffic.

⚠️ **How CompTIA Tests This:** Trigger: 'granular network security technique that restricts east-west traffic between virtual machines and cloud containers to prevent lateral movement'. Answer: Microsegmentation.

📌 Access Control Lists: Standard vs. Extended ACLs

🏠 **Real-World Analogy:** An ACL is a bouncer's guest registry clipboard. A 'Standard ACL' only checks one basic attribute: 'Where are you coming from?' (source IP). An 'Extended ACL' acts as a forensic inspector, checking origin (source IP), destination address, transport protocol (TCP/UDP), and designated service port (e.g., port 443). At the bottom sits the golden rule: 'Anyone not explicitly listed is turned away' (Implicit Deny).

🔍 **Root Cause & Background:** Network routing hardware requires deterministic, high-speed packet filtering. Without sequential rule evaluation terminating in an authoritative Implicit Deny, unauthorized traffic slips through by virtue of omission.

🛡️ **GRC Auditor Perspective:** Audit firewall and router access control policies; verify that no overly permissive 'permit any any' rules exist and confirm that terminal Implicit Deny rules are actively dropping and logging unapproved traffic.

⚠️ **How CompTIA Tests This:** Trigger: 'terminal rule automatically blocking all traffic that does not match prior permit statements'. Answer: Implicit Deny. Comparison cue: Standard ACL filters only by source IP; Extended ACL filters by source IP, destination IP, protocol, and port.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Logical segregation of business units on shared physical switching hardware to restrict broadcasts	**VLAN (Virtual Local Area Network)**
Perimeter network zone hosting internet-accessible public services isolated from internal resources	**DMZ / Screened Subnet**
Complete physical and electrical disconnection of a critical host from all external networks	**Air Gap (e.g., Offline Root CA)**
Granular cloud security policies controlling east-west traffic between containers and VMs	**Microsegmentation**
Terminal ACL rule enforcing automated drops for any traffic not matched by previous statements	**Implicit Deny**
Packet filter evaluating source IP, destination IP, protocol, and transport layer port numbers	**Extended ACL**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company has Finance and Engineering teams connected to the same physical Layer 2 switch. The security team wants to prevent broadcast traffic and casual lateral movement between the two teams while still allowing controlled traffic through the firewall. Which segmentation approach should they implement?

A) Create separate VLANs for Finance and Engineering and route inter-VLAN traffic through the firewall.

B) Place Finance servers in a DMZ and leave Engineering on the internal LAN.

C) Use a single subnet with a denylist that blocks known attacker IP addresses.

D) Enable microsegmentation only on the Finance database server.

QUESTION 2 · EXAM SCENARIO

An organization hosts a public e-commerce web server that must receive HTTPS connections from the internet. The internal database must not be directly reachable from the internet, but the web server needs limited database access. Where should the web server be placed?

A) In an internal VLAN with the database server and a host-based firewall.

B) In a screened subnet/DMZ with firewall rules allowing HTTPS inbound and only required database traffic outbound.

C) On the guest Wi-Fi network with NAT to the database.

D) On the same subnet as employee workstations to simplify administration.

QUESTION 3 · EXAM SCENARIO

Administrators need to manage a jump server. Only two known administrator IP addresses should be allowed to initiate SSH sessions, and every other source must be rejected. Which access control approach should be configured?

A) A denylist with default allow that blocks known bad administrator IPs.

B) An allowlist with default deny that permits only the two administrator IPs.

C) A DMZ that places the jump server between two firewalls.

D) A VLAN that assigns the jump server to the database broadcast domain.

QUESTION 4 · EXAM SCENARIO

A company wants employees to browse most internet websites, but it needs to block access to a known list of phishing domains. The security team does not want to approve every legitimate website. Which filtering approach best fits this requirement?

A) Allowlist with default deny.

B) Denylist with default allow.

C) DMZ with default deny.

D) Microsegmentation with default deny.

QUESTION 5 · EXAM SCENARIO

A data center has many virtual machines on one large VLAN. After one VM is compromised, the attacker moves laterally to other VMs using allowed east-west traffic. Which control best limits this type of movement between individual workloads?

A) A single perimeter firewall at the internet edge.

B) Microsegmentation policies applied between individual workloads.

C) A DMZ that contains all internal virtual machines.

D) A denylist of known malware file hashes on the hypervisor.

QUESTION 6 · EXAM SCENARIO

A company wants internal employees to perform the same identity verification and authorization checks as remote users before accessing each internal application. Network location should no longer imply trust. Which security model should be adopted?

A) Zero Trust.

B) Screened subnet.

C) VLAN trunking.

D) Denylist-based filtering.

QUESTION 7 · EXAM SCENARIO

A network engineer needs to divide 172.16.10.0/24 into four separate IP networks for different departments. Each network must be routable and controlled by firewall rules between departments. Which concept is being used?

A) Subnetting.

B) DMZ placement.

C) Allowlisting.

D) Microsegmentation.

QUESTION 8 · EXAM SCENARIO

A router connects a public network to a web server segment. The administrator needs the router to permit TCP 443 to the web server and reject all other traffic destined for that server. What should be configured on the router?

A) An ACL applied to the relevant interface.

B) A VLAN assigned to the web server switch port.

C) A screened subnet with no firewall rules.

D) A denylist for DNS queries.

QUESTION 9 · EXAM SCENARIO

A firewall rule for an internal HR application currently permits any source to reach it and then denies a list of known malicious IP addresses. An auditor says this is too permissive. What change best aligns the rule with least privilege?

A) Replace the rule with an allowlist that permits only the HR subnet and denies all other sources.

B) Add more known malicious IP addresses to the existing deny list.

C) Move the HR application to a DMZ and allow all internal subnets.

D) Create one VLAN for all departments so the firewall rule is simpler.

QUESTION 10 · EXAM SCENARIO

Contractors use a guest Wi-Fi network and need internet access, but they must not reach internal file servers or employee subnets. Which design best enforces this requirement?

A) Place guest Wi-Fi on a separate VLAN/subnet and apply ACLs that deny access to internal address ranges.

B) Place guest Wi-Fi in the DMZ and allow all internal file server traffic.

C) Use a denylist of known contractor devices on the internal LAN.

D) Enable microsegmentation only on the internal file servers while leaving guest Wi-Fi on the internal VLAN.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Create separate VLANs for Finance and Engineering and route inter-VLAN traffic through the firewall.

Separate VLANs create distinct Layer 2 broadcast domains on the same physical switch and can force inter-VLAN traffic through a router or firewall. A DMZ is for exposed services, a denylist does not isolate internal departments, and microsegmentation on one server does not segment the teams.

Question 2: Option B — In a screened subnet/DMZ with firewall rules allowing HTTPS inbound and only required database traffic outbound.

A screened subnet/DMZ isolates internet-facing services from the internal network. Firewall rules can permit HTTPS inbound and restrict outbound traffic to only the required database service. Internal VLAN with DB increases exposure, guest Wi-Fi is inappropriate, and workstation subnet increases lateral movement.

Question 3: Option B — An allowlist with default deny that permits only the two administrator IPs.

An allowlist with default deny permits only explicitly approved sources and rejects all others, which exactly matches the requirement. A denylist with default allow would let unknown sources attempt access unless listed as bad. DMZ and VLAN are segmentation concepts, not source-specific SSH authorization.

Question 4: Option B — Denylist with default allow.

A denylist with default allow blocks known bad domains while permitting all other traffic, which fits a broad internet browsing policy. An allowlist would require approving every allowed site. DMZ and microsegmentation are segmentation controls, not website category filtering.

Question 5: Option B — Microsegmentation policies applied between individual workloads.

Microsegmentation enforces granular, workload-level policies and can block unnecessary east-west traffic even inside the same VLAN. A perimeter firewall does not control internal VM-to-VM traffic well, a DMZ is for exposed services, and file-hash denylists do not stop network lateral movement.

Question 6: Option A — Zero Trust.

Zero Trust removes implicit trust based on network location and requires continuous verification and least-privilege authorization for each request. Screened subnets and VLANs are segmentation tools, and denylist filtering only blocks known bad items.

Question 7: Option A — Subnetting.

Subnetting divides a larger IP network into smaller logical IP networks that can be routed and filtered between each other. A DMZ is a specific screened segment for exposed services, allowlisting is an access control approach, and microsegmentation is usually workload-level policy enforcement.

Question 8: Option A — An ACL applied to the relevant interface.

An ACL is a set of permit or deny rules evaluated against traffic, often on router or firewall interfaces. It can permit TCP 443 and deny all other traffic to the server. VLANs provide Layer 2 segmentation but not detailed allow/deny rules, a screened subnet still needs rules, and DNS denylisting does not control web traffic.

Question 9: Option A — Replace the rule with an allowlist that permits only the HR subnet and denies all other sources.

The current rule uses default allow with a denylist. Least privilege requires an allowlist with default deny: only the HR subnet should be permitted, and all other sources should be denied. Adding bad IPs leaves unknown sources allowed, DMZ placement does not fix overly broad access, and a single VLAN increases exposure.

Question 10: Option A — Place guest Wi-Fi on a separate VLAN/subnet and apply ACLs that deny access to internal address ranges.

A separate guest VLAN/subnet isolates contractors at Layer 2/3, and ACLs can deny traffic to internal RFC1918 address ranges while permitting internet access. DMZ with internal access violates the requirement, a device denylist is weak, and leaving guest Wi-Fi on the internal VLAN risks lateral movement.